ISO 31073 Risk management — Vocabulary

moving from ISO Guide 73 version 2009

to ISO 31073 version 2022

G31000

a guidance into the new Risk management — Vocabulary standard

Geneva, 8th October 2022

Free access

In collaboration with ISO, we are pleased to provide you a free ready-only access to

- the ISO 31073:2022 - Risk management — Vocabulary standard
  https://www.iso.org/obp/ui/#iso:std:iso:31073:ed-1:v1:en

- the ISO 3100:2018 - Risk management — standard
  https://www.iso.org/obp/ui#iso:std:iso:31000:ed-2:v1:en

Disclaimer

The designations employed and the presentation of the material in this publication do not imply the expression of any opinion whatsoever on the part of the Secretariat of the International Standardization Organization (ISO) or the permanent ISO member representative of the international committee ISO TC 262. This publication does not purport to include all the necessary provisions of a contract. Users are responsible for its correct understanding and application. Compliance with ISO Standards or their national version cannot confer immunity from legal obligations.

G31000 - The Global Institute for Risk Management Standards
Balexert Tower, Avenue Louis-Casai 18, 1209 Geneva, Switzerland
Email : Headquarters@G31000.org
Website: www.G31000.org

Introduction

G31000

ISO Guide 73:2009

- **Purpose : basic vocabulary on risk management concepts**
- **Risk management is application specific : use a language meaningful for your organization**

ISO 31073:2022

- **Purpose : basic vocabulary on risk management concepts**
- **Risk management is application specific: use a language meaningful for your organization.**
- **The terminology in this document may need to be replaced by disciplinary-specific terminology where appropriate**

Introduction

G31000

ISO Guide 73:2009

- **Broad application** – any types of risks, in any application, industry or sectors
- Terms apply for managing **threats** & potential **opportunities**
- Scope :

  - mutual and consistent understanding of vocabulary related to risk

  - uniform risk management terminology in processes and frameworks

  - coherent approach

ISO 31073:2022

- **Broad application** - any types of risks, in any application, any industry or sectors
- Terms apply for managing **threats** & potential **opportunities**
- Benefits :

move to benefits

- same

Introduction

G31000

ISO Guide 73:2009

- **Users :**
  - those engaged in managing risks
  - those using ISO standards
  - developers of national or sector-specific standards, guides, procedures and codes of practice related to the management of risk
- **Structure :**
  - Terms related to risk
  - Terms related to risk management
  - Terms related to risk management process

ISO 31073:2022

- **Users :**
  - those engaged in managing risks
  - those using ISO standards
  - developers of national or sector-specific standards, guides, procedures and codes of practice related to the management of risk
- **Structure :**
  - Terms related to risk
  - Terms related to risk management
  - Terms related to risk management process

ISO 31073:2022 and ISO Guide 73:2009

G31000

- **COMMUNICATION & CONSULTATION**
- CONSEQUENCE
- **CONTROL**
- **ESTABLISHING THE CONTEXT**
- EVENT
- EXPOSURE
- EXTERNAL CONTEXT
- FREQUENCY
- HAZARD
- **INTERESTED PARTY**
- INTERNAL CONTEXT
- LEVEL OF RISK
- LIKELIHOOD
- MONITORING
- **OBJECTIVE**
- **OPPORTUNITY**
- **ORGANIZATION**
- PROBABILITY
- RESIDUAL RISK
- RESILIENCE
- REVIEW
- RISK
- RISK ACCEPTANCE
- RISK AGGREGATION
- RISK ANALYSIS
- RISK APPETITE
- RISK ASSESSMENT
- RISK ATTITUDE
- RISK AVERSION
- RISK AVOIDANCE
- **RISK CONTROL**
- RISK CRITERIA
- **RISK DESCRIPTION**
- **RISK DRIVER**
- RISK EVALUATION
- RISK FINANCING
- RISK IDENTIFICATION
- RISK MANAGEMENT
- RISK MANAGEMENT AUDIT
- **RISK MANAGEMENT FRAMEWORK**
- RISK MANAGEMENT PLAN
- RISK MANAGEMENT POLICY
- RISK MANAGEMENT PROCESS
- **RISK MATRIX**
- RISK OWNER
- RISK PERCEPTION
- **RISK PROFILE**
- **RISK REGISTER**
- RISK REPORTING
- RISK RETENTION
- RISK SHARING
- RISK SOURCE
- RISK TOLERANCE
- RISK TREATMENT
- **THREAT**
- **STAKEHOLDER**
- **UNCERTAINTY**
- VULNERABILITY

BLUE = NEW TERM ADDED RED = TERM REMOVED GRAY = TERM MAINTENED

General view about definitions

G31000

ISO Guide 73:2009

- 51 terms defined
- 9 terms removed
  - COMMUNICATION & CONSULTATION ✓
  - CONTROL
  - ESTABLISHING THE CONTEXT ✓
  - RISK DESCRIPTION ✓
  - RISK MANAGEMENT FRAMEWORK ✓
  - RISK MATRIX ✓
  - RISK PROFILE
  - RISK REGISTER ⚠
  - STAKEHOLDER ⚠
- 2 terms replaced
  - CONTROL →
  - STAKEHOLDER ⚠ →

ISO 31073:2022

- 49 terms defined
- 41 terms maintained
- 8 new terms added
  - INTERESTED PARTY ⚠
  - OBJECTIVE ✓
  - OPPORTUNITY ✓
  - ORGANIZATION ✓
  - RISK CONTROL
  - RISK DRIVER
  - THREAT ✓
  - UNCERTAINTY ✓
- 2 terms replaced
  - RISK CONTROL
  - INTERESTED PARTY ⚠

TERMS RELATED TO RISK

G31000

ISO Guide 73:2009

- **Risk** = effect of uncertainty on objectives
- Uncertainty
- Objective

Explained in a note of the definition of risk in ISO 31000:2009, but removed in version 2018

Not defined

ISO 31073:2022

- **Risk** = effect of uncertainty on objectives
- **Uncertainty** = state, even partial, of deficiency of information related to understanding or knowledge
- **Objective** = result to be achieved

TERMS RELATED TO RISK MANAGEMENT

G31000

ISO Guide 73:2009

- **risk management =** coordinated activities to direct and control an organization with regard to risk
- **risk management policy =** statement of the overall intentions and direction of an organization related to risk management
- **risk management plan =** scheme within the risk management framework specifying the approach, the management components and resources to be applied to the management of risk
- **risk management framework**

ISO 31073:2022

- **risk management**
- **risk management policy**
- **risk management plan**
- **risk management framework**

Definition entirely removed

Terms modified

G31000

41 terms maintained, but 15 definitions have been modified

- CONSEQUENCE
- EVENT
- **EXPOSURE**
- **EXTERNAL CONTEXT**
- FREQUENCY
- HAZARD
- **INTERNAL CONTEXT**
- LEVEL OF RISK
- LIKELIHOOD
- **MONITORING**
- **PROBABILITY**
- RESIDUAL RISK
- RESILIENCE
- **REVIEW**

- RISK
- RISK ACCEPTANCE
- RISK AGGREGATION
- **RISK ANALYSIS**
- RISK APPETITE
- RISK ASSESSMENT
- RISK ATTITUDE
- RISK AVERSION
- RISK AVOIDANCE
- **RISK CRITERIA**
- **RISK EVALUATION**
- RISK FINANCING
- **RISK IDENTIFICATION**
- RISK MANAGEMENT

- RISK MANAGEMENT AUDIT
- RISK MANAGEMENT PLAN
- RISK MANAGEMENT POLICY
- RISK MANAGEMENT PROCESS
- **RISK OWNER**
- **RISK PERCEPTION**
- **RISK REPORTING**
- RISK RETENTION
- **RISK SHARING**
- RISK SOURCE
- **RISK TOLERANCE**
- RISK TREATMENT
- VULNERABILITY

RED = TERM MAINTENED **WITH** MODIFICATIONS

GRAY = TERM MAINTENED **WITHOUT** MODIFICATIONS

Terms affected by changing “stakeholder”

G31000

9 terms affected by changing “stakeholder” by “interested parties”

ISO Guide 73:2009	ISO 31073:2022
9 definitions affected • EXPOSURE • EXTERNAL CONTEXT • INTERNAL CONTEXT • MONITORING • REVIEW • RISK IDENTIFICATION • RISK PERCEPTION • RISK REPORTING • RISK TOLERANCE	**Indication mentioned about the change :** ➢ “interested party” has replaced “stakeholder” -

Terms modified

Important modifications

G31000

ISO Guide 73:2009	ISO 31073:2022
Important modifications ➢ **risk sharing** = form of risk treatment involving the agreed distribution of risk with other parties	➢ Note 1 ➢ Note 2 ➢ Note 3 ~~➢ Note 4 : Risk transfer is a form of risk sharing~~ ✓ *Much clearer*
➢ **risk analysis** = process to comprehend the nature of risk and to determine the level of risk	➢ Note 1 ~~➢ Note 2 : risk analysis include risk estimation~~ ✓
➢ **risk evaluation** = process of comparing the results of risk analysis with risk criteria to determine whether the risk ~~and/or its magnitude~~ is acceptable or tolerable	*Much clearer* ✓

Other terms modified

Minor modifications

G31000

ISO Guide 73:2009	ISO 31073:2022
Minor modifications ➢ "risk" has replaced "a risk" ❑ Risk owner = person or entity with the accountability and authority to manage ~~a~~ risk ❑ risk criteria = terms of reference against which the significance of ~~a~~ risk is evaluated Probability = measure of the chance of occurrence expressed as a number ~~**between 0 and 1**~~, where 0 is impossibility and 1 is absolute certainty	**Important aspects to remember** **In practice**, *as soon as a risk is identified, a risk owner should be designated for a particular range (small, medium, large or catastrophic consequences)* **In practice**, *the significance of (a) risk should be replaced by "level of risk" in order to avoid confusion* **A number from 0 and 1**

Terms removed

Important modifications

G31000

ISO Guide 73:2009	ISO 31073:2022
Important deletions ➢ **risk matrix** = tool for ranking and displaying risks by defining ranges for consequence and likelihood ➢ **risk profile** = description of any set of risks ➢ **risk register** = record of information about identified risks ➢ **stakeholder**= person or organization that can affect, be affected by, or perceive themselves to be affected by a decision or activity	Risk Matrix is removed in order to align with ISO 31010:2019 – Risk management — Risk assessment techniques standard which prefer to use the term “Consequence likelihood matrix as technique number B.9.3. ✓ This definition is very academic. In practice, not useful ✓ This removal is unfortunate, as it is sometimes mandated by law and regulations. In ISO 31010:2019 standard, it is refered as techniques B.9.2. as it is useful in practice. ⚠ Removing and replacing “stakeholder” by “interested party” is plainly wrong, as it is today widely accepted. ⚠

New terms associated with the definition of risk

G31000

Risk = the effect of uncertainty on objectives

ISO 31000:2009 and ISO 31000:2018

NOTE 1 (ISO31000:2018): An effect is a deviation from the expected. It can be positive, negative or both. An effect can arise as a result of a response, or failure to respond, to an **opportunity** or to a **threat** related to **objectives**.

NOTE 2 (ISO31000:2009) : **Objectives** can have different aspects (such as financial, health and safety, and environmental goals) and can apply at different levels (such as strategic, organization-wide, project, product and process).

NOTE 2 (ISO31000:2018) : **Objectives** can have different aspects and categories and can be applied at different levels.

NOTE 5 (ISO31000:2009) : **Uncertainty** is the state, even partial, of deficiency of information related to, understanding or knowledge of, an event, its consequence, or likelihood.

ISO 31073:2022

Important additions

- **OBJECTIVE**
- **UNCERTAINTY**
- **OPPORTUNITY**
- **THREAT**

New terms associated with the definition of risk

G31000

Objective = result to be achieved

Only one type of category

ISO 31000:2009 and ISO 31000:2018

- NOTE 2 (ISO31000:2018) : **Objectives** can have different aspects and categories and can be applied at different levels..
- NOTE 2 (ISO31000:2009) : **Objectives** can have different aspects (such as financial, health and safety, and environmental goals) and can apply at different levels (such as strategic, organization-wide, project, product and process).

ISO 31073:2022

NOTE 1 : An objective can be strategic, tactical or operational.

NOTE 2 : Objectives can relate to different disciplines (such as financial, health and safety, and environmental goals) and can apply at different levels (such as strategic, organization-wide, project, product and process).

NOTE 3 : An objective can be expressed in other ways, e.g. as an intended outcome, a purpose, an operational criterion, as a management system objective, or by the use of other words with similar meaning (e.g. aim, goal, target).

New terms associated with the definition of risk

G31000

Uncertainty = state, even partial, of deficiency of information related to understanding or knowledge

ISO 31000:2009

NOTE 5 (ISO31000:2009) : **Uncertainty** is the state, even partial, of deficiency of information related to, understanding or knowledge ~~of, an event, its consequence, or likelihood.~~ ✓

ISO 31073:2022

- **the former note 5 become the definition**

NOTE 1 : In some cases, uncertainty can be related to the organization's context as well as to its objectives.

✓ NOTE 2 : **Uncertainty is the root source of risk**, namely any kind of "deficiency of information" that matters in relation to objectives (and objectives, in turn, relate to all relevant interested parties' needs and expectations).

interested parties = stakeholders

New terms associated with the definition of risk

G31000

Opportunity = combination of circumstances expected to be favourable to objectives

SOURCE: IEC 31010:2019

Opportunity = a combination of circumstances favourable to the purpose

Note 1 : An opportunity is a source of potential benefit or other desirable outcome.

Note 2 : An opportunity to one party may pose a threat to another.

ISO 31073:2022

Opportunity = combination of circumstances expected to be favourable to objectives

Note 1 : An opportunity is a positive situation in which gain is likely
and over which one has a fair level of control. ✓

Note 2 : An opportunity to one party may pose a threat to another. ✓

Note 3 : Taking or not taking an opportunity are both sources of risk ✓

New terms associated with the definition of risk

G31000

Threat = potential source of danger, harm, or other undesirable outcome

SOURCE: IEC 31010:2019

Threat = potential source of danger, harm etc.

ISO 31073:2022

Threat = potential source of danger, harm, or other undesirable outcome

- **Threat is the opposite of opportunity and vice versa**

Note 1 : An opportunity is a positive situation in which gain is likely and over which one has a fair level of control.

Note 2 : An opportunity to one party may pose a threat to another.

Note 1 : A threat is a negative situation in which loss is likely and over which one has relatively little control.

Note 2 : A threat to one party may pose an opportunity to another

Additional new terms

Is these 2 definitions necessary ?

G31000

Organization = person or group of people that has its own functions with responsibilities, authorities and relationships to achieve its objectives

ISO 31000:2009

Note : For convenience, all the different users of this international standard are referred to by the general term as organization

ISO 31073:2022

Note 1 : The concept of organization includes, but is not limited to, sole-trader, company, corporation, firm, enterprise, authority, partnership, charity or institution, or part or combination thereof, whether incorporated or not, public or private.

Risk driver = factor that has a major influence on risk

Conclusions

Main good features remaining in the ISO 31073:2022 Risk management — Vocabulary standard

1. The ISO 31073 Risk management — Vocabulary standard is now an integral part of the of ISO 31000-related family for risk management standards
2. Only one standard in risk management vocabulary applying to all types of risks
3. Provide a mutual and consistent understanding of vocabulary related to risk with a uniform risk management terminology in processes and frameworks with a coherent approach
4. Apply to any organization any size, activity or sector
5. Risk management vocabulary is application specific: use a language meaningful for your organization
6. The terminology in this document may need to be replaced by disciplinary-specific terminology where appropriate
7. Based on 20 years experience, input of hundreds of risk experts, thousands of public feedback, built on consensus for a single document
8. Risk vocabulary embedded in all ISO management systems standard through ISO Annex SL

Conclusions

Positive changes and aspects to watch out for

G31000

Positive

- **Out of 51 terms, 41 remains** the same
- Words associated to the definition of risk are **now defined :** *objective – uncertainty – opportunity - threat*
- Useless or academic terms are **removed** : *Communication & consultation, establishing the context, risk description, risk management framework, risk matrix*
- Vocabulary **aligned** with ISO 31010:2019 Risk assessment Techniques standard
- Many useless notes associated to definitions have been **removed**.

To keep in mind

- **Changing "stakeholder"** by "interested parties" is probably a mistake and has affected 9 other definitions
- **Deletion of risk register** is unwise as the term is widely used.

Thank you!

G31000

ISO 31073:2022 Risk management — Vocabulary

a ISO guidance standard for Vocabulary used in Risk management